

Summary

How I Used the Software

I started by creating a new model from a blank canvas. The tool lets you drag and drop standard elements like Browser, Web Server, SQL Database, and External Provider. I drew data flow lines (arrows) between components and placed a trust boundary to separate the internal system from the internet. The software automatically numbered each flow and component, which helped me keep track.

For each data flow, I selected a protocol. I chose HTTPS for external connections but left several flows as "Generic Data Flow" because I wasn't sure which protocol to pick. The tool then generated a threat report using the STRIDE framework (Spoofing, Tampering, Repudiation, Information Disclosure, Denial of Service, Elevation of Privilege).

Key Controls I Used or Learned About

- Trust Boundary Control: I placed one boundary around the internal web server and database. This told the tool that anything outside is untrusted. The tool then flagged all cross-boundary flows as high-risk.
- Protocol Selection: Each flow required a protocol choice. HTTPS enabled the tool to suggest specific threats like certificate spoofing. Generic flows triggered only vague warnings, which taught me to always be specific.
- STRIDE Mapping: The tool automatically matched each component and flow to STRIDE threats. For example, the SQL Database triggered "Elevation of Privilege" threats because the tool assumed the web server might have too much access.